Sprint 3 – Static Analysis Report

- **Project:** TrainFuel (iOS app)
- **Repository:** https://github.com/szcze006/TrainFuel
- **Branch scanned:** dev (commit e90f5ab)
- **Scan date:** October 20, 2026

---

1. Tools Used

Item	Details
Programming language	Swift (SwiftUI), with Firebase as the backend
SonarQube version/ edition	SonarQube Cloud, Free plan, automatic analysis, "Sonar way" quality profile and quality gate
Trivy version	Trivy 0.76.0
Trivy scan type	Filesystem scan of the Git repository (`trivy repo`), covering dependencies (Swift Package Manager), secrets and misconfigurations
Where SonarQube ran	SonarQube Cloud (cloud-hosted automatic analysis of the GitHub repository)
Where Trivy ran	Local (macOS)

---

2. Required Metrics

SonarQube

Metric	Result
Bugs (Reliability)	0
Vulnerabilities (Security)	0
Code Smells (Maintainability)	0
Security Hotspots	0
Quality Gate	Not computed

Reliability, Security and Maintainability were all rated **A**. Duplications were 0.0% and there were 0 accepted issues.

SonarQube Cloud now groups issues as Reliability, Security and Maintainability, which correspond to Bugs, Vulnerabilities and Code Smells.

The Quality Gate shows **Not computed** because this was the first analysis of the project. The "Sonar way" gate only evaluates new code, so a Pass/Fail status is shown from the next analysis onward. No issues of any type were found in this analysis.

Trivy

Severity	Count
CRITICAL	0
HIGH	0
MEDIUM	0
LOW	0

Trivy found no vulnerabilities, no secrets and no misconfigurations.

---

3. Scope

What was scanned:

- **SonarQube:** all source code on the dev branch, which is about 3.2k lines of Swift code in `MyApp/` (`ContentView.swift`, `PerformanceHubView.swift`, `SportCoach.swift`, `MyApp.swift`). The scan was run on a fork of the team repository (micze001/TrainFuel) at the same dev commit (e90f5ab), because SonarQube Cloud can only import repositories from the user's own GitHub account.
- **Trivy:** the full dev branch of the team repository. This included the 13 Swift packages listed in `Package.resolved` (Firebase iOS SDK 12.19.2 and its Google dependencies) and a secret scan of every file.

What was excluded:

- No files were manually excluded.
- The source code of third-party packages (for example, the Firebase SDK) is not stored in the repository, so it was not analyzed by SonarQube. Trivy checked these packages by version against its vulnerability database.
- Test coverage was not measured because the project does not have automated tests yet.

---

4. Trend

Baseline sprint — no prior comparison.

---

5. Reflection

Both tools reported zero issues, so the most problematic area is maintainability risk rather than a specific finding. `ContentView.swift` holds about 3,660 lines and most of the app's screens, which makes it harder to review and test. Next sprint we plan to split it into smaller view files, add unit tests with coverage reporting, and run both scans again so the Quality Gate is computed and issue counts can be compared.

Required Statement

This static analysis was generated using automated tools during this sprint.